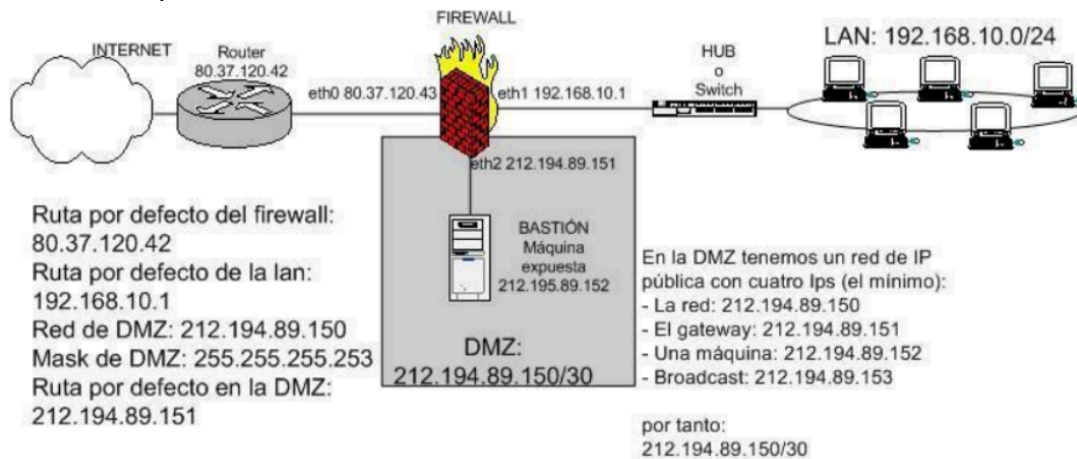


Parcial II
Seguridad Informática
Ingeniería de Sistemas y Computación – Universidad de Caldas
Daniela Agudelo Martinez - 0000031586

1. (40%) Con base en la arquitectura definida en la Figura, modelar un conjunto de reglas vía Netfilter/Iptables o UFW, así:



a. Permitir el tráfico de los clientes LAN a los Web Servers de la DMZ (*.151, *.152).
Este comando utiliza el principio de mínimo privilegio, limitando el acceso únicamente al servicio necesario.

Usamos la cadena FORWARD porque el tráfico no es para el firewall, sino que lo atraviesa hacia otra red. Al especificar -p tcp --dport 80, se garantiza que la LAN solo pueda realizar peticiones HTTP a los servidores. Esto hace que no se pueda saber de otros servicios internos que podrían ser vulnerables si se permitiera todo el tráfico

```
# Permitir acceso desde la LAN a la IP del gateway expuesto en DMZ
sudo iptables -A FORWARD -i eth1 -o eth2 -s 192.168.10.0/24 -d 212.194.89.151 -p tcp -m multiport --dports 80,443 -j ACCEPT

# Permitir acceso desde la LAN a la IP del servidor expuesto en DMZ
sudo iptables -A FORWARD -i eth1 -o eth2 -s 192.168.10.0/24 -d 212.194.89.152 -p tcp -m multiport --dports 80,443 -j ACCEPT
```

b. Permitir el tráfico desde Internet hacia los servidores de la DMZ WWW & email Server

En este caso filtramos por la interfaz de entrada -i eth0 para mayor seguridad.. El uso de -m multiport permite agrupar los puertos 80 (HTTP), 443 (HTTPS) y 25 (SMTP/Email) en una sola regla

```
# Se permite tráfico web (80) - (443) y correo (25) hacia la máquina pública (.152)
sudo iptables -A FORWARD -i eth0 -o eth2 -d 212.194.89.152 -p tcp -m multiport --dports 80,443,25 -j ACCEPT
```

c. Proteger el Router de la DMZ y de la LAN para tráfico ICMP y Telnet

Aquí usamos la cadena INPUT porque el destino final del paquete es el propio router. Al especificar las direcciones de destino exactas, evitamos que cualquier usuario realice un ping para mapear la red o intente una conexión por Telnet

```
sudo iptables -A INPUT -d 212.194.89.151 -p icmp -j DROP
sudo iptables -A INPUT -d 212.194.89.151 -p tcp --dport 23 -j DROP
sudo iptables -A INPUT -d 192.168.10.1 -p icmp -j DROP
sudo iptables -A INPUT -d 192.168.10.1 -p tcp --dport 23 -j DROP
```

d. Precisar semánticamente una regla de Detección de Intrusiones (basada en Snort) que permita alertar intentos de elevar privilegios ("sudo -i") a cualquier servidor de la DMZ.

Aquí se define el origen desde cualquier IP y puerto, ya que un ataque de elevación de privilegios puede venir de una sesión ya establecida por SSH, una shell reversa u otro medio. Además se protege todo el rango

```
alert tcp any any -> 212.194.89.150/30 any (msg:"ALERTA: Intento de
escalado de privilegios detectado en DMZ"; content:"sudo -i"; nocase;
sid:1000002; rev:1;)
```

2. (30%)

a. Brevemente describa el funcionamiento (fases) de SSL/TLS.

Para explicar el funcionamiento, debemos ver a SSL/TLS como un proceso de dos niveles que protege la comunicación en la capa de transporte

Primero tenemos el Protocolo de Negociación, llamado Handshake. Esta es la fase previa al envío de datos. Aquí, el cliente y el servidor se presentan, acuerdan qué versión del protocolo y qué algoritmos criptográficos usarán. El servidor envía su Certificado Digital (validado por una CA) para demostrar su identidad. Finalmente, generan una clave maestra secreta que solo ellos conocen para esa sesión específica.

Por otro lado, tenemos el Protocolo de Registro, o Record. Una vez se establece la confianza, este protocolo se encarga del trabajo pesado. Toma los datos de la aplicación, los fragmenta en bloques manejables, opcionalmente los comprime y les aplica un MAC (Message Authentication Code) para que nadie pueda alterarlos sin ser detectado. Finalmente, los cifra con la clave acordada en el Handshake para asegurar que, si alguien los captura (sniffing), no pueda leerlos.

b. Describa las principales diferencias entre un modelo de certificación basado en PKI con certificados digitales y el estándar PGP

La diferencia radica en en quién confiamos para validar una identidad.

- PKI: Se basa en una estructura centralizada y vertical. Existe una entidad de máxima confianza llamada Autoridad de Certificación (CA). Si un usuario confía en la CA,

automáticamente confía en todos los certificados emitidos o firmados por ella. Es un modelo delegativo.

- PGP: Es un modelo descentralizado y horizontal basado en confianza. Aquí no existen las CA, no hay un jefe central, yo confío en un usuario porque alguien en quien yo ya confío firmó su clave.

Si un Usuario A confía en un Usuario B, y el Usuario B ha firmado la clave del Usuario C, el Usuario A puede elegir confiar en el Usuario C. La confianza se construye de manera comunitaria y acumulativa.

c. ¿Por qué las funciones de hashing son el núcleo de la firmas digitales y del blockchains?

El hashing es una función matemática que convierte cualquier volumen de datos en un resumen de longitud fija y única.

En Firmas Digitales no se cifra el mensaje completo con la clave privada (sería muy lento) sino que se cifra solo el hash del mensaje. Esto garantiza la integridad ya que si el receptor calcula el hash del mensaje recibido y este coincide con el de la firma, se garantiza que el contenido no fue alterado.

En Blockchain el hash actúa como el eslabón de la cadena. Cada bloque nuevo contiene el hash del bloque anterior. Esto crea una cadena inmutable pues si alguien intentara cambiar un solo bit de información en un bloque viejo, su hash cambiaría, rompiendo todos los hashes de los bloques siguientes y dejando al descubierto el fraude inmediatamente.

3. (30 %)

a. Describa la funcionalidad de una inyección SQL y enumere al menos 2 contramedidas.

La inyección SQL es un ataque donde el atacante inserta comandos de base de datos dentro de campos de texto de una página web (como un login). Si la aplicación no está protegida, el servidor ejecuta ese código malicioso, permitiendo al atacante saltarse contraseñas o borrar tablas enteras.

La primera contramedida sería usar sentencias preparadas ya que es la defensa más efectiva. En lugar de enviar una cadena de texto larga a la base de datos, enviamos la consulta con huecos vacíos para los datos. Así, la base de datos sabe de antemano qué es código y qué es simplemente un dato, ignorando cualquier comando malicioso insertado.

La segunda contramedida es la de tener mínimos privilegios. El usuario que la aplicación usa para conectarse a la base de datos no debe ser el administrador (root). Solo debe tener permiso para hacer lo estrictamente necesario (por ejemplo, solo leer y escribir en su tabla específica), limitando el daño si ocurre una inyección.

b. Especifique 4 controles mínimos para el desarrollo seguro de aplicaciones orientadas a servicios.

Para que un servicio sea considerado seguro, debe seguir el Ciclo de Vida de Desarrollo de Seguridad, el cual consiste en lo siguiente:

- La idea es garantizar que toda la comunicación entre el cliente y el servicio viaje cifrada para evitar el olfateo de datos sensibles, aquí se usa Cifrado TLS
- Es necesario Implementar mecanismos como tokens (JWT) para asegurar que el usuario es quien dice ser y que tiene permiso para acceder a ese recurso específico. En general, se necesita una autenticación y autorización fuerte.
- Se debe filtrar todas las peticiones para rechazar caracteres sospechosos o formatos inesperados antes de procesarlos. En síntesis, hacer saneamiento y validación de entradas
- Otro control importante tiene que ver con la gestión de vulnerabilidades de terceros, ya que gran porcentaje de las fallas vienen de librerías externas. Es importante auditar y actualizar constantemente las dependencias del proyecto

c. Plantee al menos una contramedida (1 por categoría) para los 4 primeros vectores de ataques de OWASP Top 10.



Imagen tomada de la presentación

1. Broken Access Control

Este vector se refiere a la falla en la aplicación de políticas de restricción, permitiendo a los usuarios actuar fuera de sus permisos previstos. Como contramedida, se debe implementar un modelo de mínimos privilegios de forma estricta. Esto se puede lograr mediante el uso de Tokens JWT para la gestión de identidad en el Frontend, y la implementación de protocolos robustos como OAuth y SSO (Single Sign-On) con autenticación de múltiples factores (2FA).

Además, a nivel de código, se pueden utilizar APIs como AccessController de ESAPI para centralizar y verificar las reglas de acceso en cada petición.

2. Cryptographic Failure

Se enfoca en la falta de protección de datos tanto en reposo como en tránsito. Como contramedida, se debe tener la comunicación cifrada de extremo a extremo usando TLS. Para proteger las contraseñas, nunca se deben almacenar en texto claro, sino aplicar funciones de hashing como SHA-256 o SHA-512.

Adicionalmente, se debe configurar la cabecera HSTS (Strict Transport Security) para obligar al navegador a usar siempre conexiones HTTPS, evitando ataques de sniffing en canales inseguros.

3. Injection

Este riesgo ocurre cuando datos no confiables se envían como parte de un comando o consulta. Aquí la contramedida es el uso de sentencias preparadas o apis parametrizadas ya que de esta manera se define la estructura de la consulta SQL con huecos, enviando los datos como parámetros independientes. Esto asegura que el motor de la base de datos no interprete la entrada del usuario como código ejecutable.

También se deben aplicar procesos de limpieza, filtrado y escape de todas las cadenas raras en las APIs

4. Insecure Design

Se enfoca en los riesgos relacionados con fallas en el diseño y la arquitectura de la aplicación, que no pueden corregirse con una implementación perfecta si el concepto base ya es erróneo. La contramedida es integrar un ciclo de vida de desarrollo de seguridad que integre puntos importantes desde la capacitación inicial hasta el modelado de amenazas y requisitos de diseño seguro

Es importante también realizar un análisis de vulnerabilidades basado en los vectores de OWASP y desplegar un Web Application Firewall con reglas específicas para detectar patrones de ataque desde la fase de diseño y despliegue